NAME: PREETI KALBURGI

SRN: PES1UG24AM203

CLASS: AIML 5D

SE | Lab 5: Static Code Analysis

1. Objective

To improve Python code quality, security, and formatting using Pylint, Bandit, and Flake8.

2. Tools Used

- **Pylint:** Evaluates code quality, naming conventions, documentation, and potential programming issues.
- **Bandit:** Identifies potentially insecure coding patterns.
- **Flake8:** Checks Python style and formatting violations.

3. Project Description

The Wildlife Sightings program records wildlife sightings, calculates the total number of sightings in a zone, generates an observer identifier, and identifies the species with the lowest recorded count.

4. Issues Identified and Fixed

The original analysis identified the following issues:

- Mutable default argument in logSighting().
- Potential SQL injection due to string-based SQL query construction.
- Use of MD5 hashing.
- Use of an assert statement.
- Function names that did not follow snake_case.
- Missing module and function docstrings.
- Excessively long lines and inconsistent formatting.
- An ambiguous variable name and missing whitespace.

The code was updated to address these findings while preserving the program's main functionality.

Issue	Type	Line(s)	Description	Fix Approach
Potential SQL injection	Security – Medium	9	SQL query constructed using string formatting, allowing potentially unsafe input to alter the query.	Replaced string formatting with parameterized SQL queries using ? placeholders.
Weak MD5 hashing	Security – High	15	MD5 is a weak hashing algorithm for security-sensitive purposes.	Replaced MD5 with SHA-256.
Use of assert	Security – Low	36	Assertions can be disabled when Python runs in optimized mode.	Replaced assert with an explicit if condition and ValueError.
Mutable default argument	Bug / Code Quality	8	Using {} as a default argument can cause data to be shared across function calls.	Replaced {} with None and initialized a new dictionary inside the function.
Incorrect function naming	Code Style	8, 14, 18	Function names did not follow Python's snake_case naming convention.	Renamed functions to log_sighting, observer_id, and zone_summary.
Missing docstrings	Code Quality	1, 8, 14, 18, 26, 32	The module and functions lacked descriptive documentation.	Added module and function docstrings.
Long lines	Formatting	5, 9, 19, 27	Lines exceeded the recommended character limit.	Split long statements across multiple lines.
Unnecessary else	Code Quality	20	An else block was used after a return statement.	Removed the unnecessary else and moved the return statement outside the block.
Ambiguous variable name	Formatting	28	The variable l could be confused with the number 1.	Renamed it to rarest_sighting.
Missing whitespace around operator	Formatting	28	The assignment expression did not follow standard spacing conventions.	Added appropriate whitespace around the operator.
Missing final newline	Formatting	79	The file did not end with a newline character.	Added a newline at the end of the file.
Redefined conn variable	Code Quality	8, 18, 26	Function parameters shadowed the global database connection variable.	Renamed the global connection to db_connection.

5. Results

Tool	Before Fixes	After Fixes
Pylint	3.46/10	10.00/10
Bandit	3 findings: 1 high, 1 medium, 1 low	No issues identified
Flake8	6 reported violations	No issues reported

before: pylint_before.txt

```
(venv) PS C:\Users\Preeti Kalburgi\Desktop\SE_lab5\L5_21_wildlife_sightings> Get-Content pylint_before.txt
************ Module wildlife_sightings
wildlife_sightings.py:5:0: C0301: Line too long (103/100) (line-too-long)
wildlife_sightings.py:9:0: C0301: Line too long (117/100) (line-too-long)
wildlife_sightings.py:1:0: C0114: Missing module docstring (missing-module-docstring)
wildlife_sightings.py:8:0: C0116: Missing function or method docstring (missing-function-docstring)
wildlife_sightings.py:8:0: C0103: Function name "logSighting" doesn't conform to snake_case naming style (invalid-name)
wildlife_sightings.py:8:0: W0102: Dangerous default value {} as argument (dangerous-default-value)
wildlife_sightings.py:8:16: W0621: Redefining name 'conn' from outer scope (line 4) (redefined-outer-name)
wildlife_sightings.py:9:17: C0209: Formatting a regular string which could be an f-string (consider-using-f-string)
wildlife_sightings.py:14:0: C0116: Missing function or method docstring (missing-function-docstring)
wildlife_sightings.py:14:0: C0103: Function name "observerId" doesn't conform to snake_case naming style (invalid-name)
wildlife_sightings.py:18:0: C0116: Missing function or method docstring (missing-function-docstring)
wildlife_sightings.py:18:0: C0103: Function name "zoneSummary" doesn't conform to snake_case naming style (invalid-name)
wildlife_sightings.py:18:16: W0621: Redefining name 'conn' from outer scope (line 4) (redefined-outer-name)
wildlife_sightings.py:20:4: R1705: Unnecessary "else" after "return", remove the "else" and de-indent the code inside it (no-else-return)
wildlife_sightings.py:26:0: C0116: Missing function or method docstring (missing-function-docstring)
wildlife_sightings.py:26:11: W0621: Redefining name 'conn' from outer scope (line 4) (redefined-outer-name)
wildlife_sightings.py:32:0: C0116: Missing function or method docstring (missing-function-docstring)

-----------------------------------
Your code has been rated at 3.46/10
```

After: pylint_after.txt

```
(venv) PS C:\Users\Preeti Kalburgi\Desktop\SE_lab5\L5_21_wildlife_sightings> python -m pylint wildlife_sightings.py

--------------------------------------------------------------------
Your code has been rated at 10.00/10 (previous run: 10.00/10, +0.00)
```

Before: bandit_before.txt

```
(venv) PS C:\Users\Preeti Kalburgi\Desktop\SE_lab5\L5_21_wildlife_sightings> Get-Content bandit_before.txt
python : [main] INFO    profile include tests: None
At line:1 char:1
+ python -m bandit wildlife_sightings.py *> bandit_before.txt
+ ~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~
    + CategoryInfo          : NotSpecified: ([main]  INFO    profile include tests: None:String) [], RemoteException
    + FullyQualifiedErrorId : NativeCommandError

[main]  INFO    profile exclude tests: None
[main]  INFO    cli include tests: None
[main]  INFO    cli exclude tests: None
[main]  INFO    running on Python 3.11.9
Run started:2026-10-28 02:58:20.216987+00:00

Test results:
>> Issue: [B608:hardcoded_sql_expressions] Possible SQL injection vector through string-based query construction.
   Severity: Medium   Confidence: Medium
   CWE: CWE-89 (https://cwe.mitre.org/data/definitions/89.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b608_hardcoded_sql_expressions.html
   Location: .\wildlife_sightings.py:9:17
8       def logSighting(conn, species, zone, count, extras={}):
9           conn.execute("INSERT INTO sightings (species, zone, count) VALUES ('{}', '{}', {})".format(species, zone, count))
10          extras[species] = extras.get(species, 0) + count

--------------------------------------------------
>> Issue: [B324:hashlib] Use of weak MD5 hash for security. Consider usedforsecurity=False
   Severity: High   Confidence: High
   CWE: CWE-327 (https://cwe.mitre.org/data/definitions/327.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b324_hashlib.html
   Location: .\wildlife_sightings.py:15:11
14      def observerId(observer):
15          return hashlib.md5(observer.encode()).hexdigest()[:6]
16

--------------------------------------------------
>> Issue: [B101:assert_used] Use of assert detected. The enclosed code will be removed when compiling to optimised byte code.
   Severity: Low   Confidence: High
   CWE: CWE-703 (https://cwe.mitre.org/data/definitions/703.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b101_assert_used.html
   Location: .\wildlife_sightings.py:36:4
35          logSighting(conn, "Hornbill", "East", 3, totals)
36          assert len(totals) == 3
37          print(observerId("Arun"), zoneSummary(conn, "North"), rarest(conn))

--------------------------------------------------

Code scanned:
        Total lines of code: 27
        Total lines skipped (#nosec): 0
        Total potential issues skipped due to specifically being disabled (e.g., #nosec BXXX): 0

Run metrics:
        Total issues (by severity):
                Undefined: 0
                Low: 1
                Medium: 1
                High: 1
        Total issues (by confidence):
                Undefined: 0
                Low: 0
```

After: bandit_after.txt

```
(venv) PS C:\Users\Preeti Kalburgi\Desktop\SE_lab5\L5_21_wildlife_sightings> python -m bandit wildlife_sightings.py
[main]  INFO    profile include tests: None
[main]  INFO    profile exclude tests: None
[main]  INFO    cli include tests: None
[main]  INFO    cli exclude tests: None
[main]  INFO    running on Python 3.11.9
Run started:2026-10-28 03:41:59.524777+00:00

Test results:
        No issues identified.

Code scanned:
        Total lines of code: 52
        Total lines skipped (#nosec): 0

Run metrics:
        Total issues (by severity):
                Undefined: 0
                Low: 0
                Medium: 0
                High: 0
        Total issues (by confidence):
                Undefined: 0
                Low: 0
                Medium: 0
                High: 0
Files skipped (0):
```

Before: flake8_before.txt

```
(venv) PS C:\Users\Preeti Kalburgi\Desktop\SE_lab5\L5_21_wildlife_sightings> Get-Content flake8_before.txt
wildlife_sightings.py:5:80: E501 line too long (103 > 79 characters)
wildlife_sightings.py:9:80: E501 line too long (117 > 79 characters)
wildlife_sightings.py:19:80: E501 line too long (93 > 79 characters)
wildlife_sightings.py:27:80: E501 line too long (96 > 79 characters)
wildlife_sightings.py:28:5: E741 ambiguous variable name 'l'
wildlife_sightings.py:28:6: E225 missing whitespace around operator
```

After: flake8_after.txt

```
(venv) PS C:\Users\Preeti Kalburgi\Desktop\SE_lab5\L5_21_wildlife_sightings> python -m flake8 wildlife_sightings.py
```

Screenshot of the final output with issues fixed:

```
(venv) PS C:\Users\Preeti Kalburgi\Desktop\SE_lab5\L5_21_wildlife_sightings> python wildlife_sightings.py
e753d3 25 Leopard
(venv) PS C:\Users\Preeti Kalburgi\Desktop\SE_lab5\L5_21_wildlife_sightings> python -m pylint wildlife_sightings.py

--------------------------------------------------------------------
Your code has been rated at 10.00/10 (previous run: 10.00/10, +0.00)

(venv) PS C:\Users\Preeti Kalburgi\Desktop\SE_lab5\L5_21_wildlife_sightings> python -m bandit wildlife_sightings.py
[main]  INFO    profile include tests: None
[main]  INFO    profile exclude tests: None
[main]  INFO    cli include tests: None
[main]  INFO    cli exclude tests: None
[main]  INFO    running on Python 3.11.9
Run started:2026-10-28 03:41:59.524777+00:00

Test results:
        No issues identified.

Code scanned:
        Total lines of code: 52
        Total lines skipped (#nosec): 0

Run metrics:
        Total issues (by severity):
                Undefined: 0
                Low: 0
                Medium: 0
                High: 0
        Total issues (by confidence):
                Undefined: 0
                Low: 0
                Medium: 0
                High: 0
Files skipped (0):
(venv) PS C:\Users\Preeti Kalburgi\Desktop\SE_lab5\L5_21_wildlife_sightings> python -m flake8 wildlife_sightings.py
(venv) PS C:\Users\Preeti Kalburgi\Desktop\SE_lab5\L5_21_wildlife_sightings>
```

Description:

The static code analysis tools identified several issues in the original Wildlife Sightings Python program. Pylint detected a mutable default argument, missing docstrings, incorrect function naming conventions, unnecessarily long lines, and an unnecessary else statement. The mutable default argument was replaced with None, function names were changed to snake_case, docstrings were added, and the code was reorganized for better readability. Bandit identified a potential SQL injection vulnerability caused by constructing SQL queries using string formatting, the use of the weak MD5 hashing algorithm, and an assert statement. These issues were addressed by using parameterized SQL queries, replacing MD5 with SHA-256, and replacing the assertion with an explicit conditional check. Flake8 identified formatting issues, including long lines, an ambiguous variable name, missing whitespace around an operator, and a missing final newline. These were corrected to improve code readability and maintain consistent Python coding standards. After applying the fixes, the program executed successfully, Pylint achieved a score of 10.00/10, Bandit reported no issues, and Flake8 reported no violations.

6. Verification

The updated program was executed successfully. Its output confirmed that the North zone contained 25 sightings and that Leopard was the species with the lowest total count in the sample data.

The three static analysis tools were run again after the fixes to verify the improvements.

7. Git Commits

The work was organized into three tool-related commits:

1. Fix Pylint code quality issues
2. Fix Bandit security issues
3. Fix Flake8 formatting issues

Additional documentation commits were used to preserve the analysis reports and issue documentation.

8. Conclusion

This lab demonstrated how static analysis tools can identify code quality problems, potential security vulnerabilities, and formatting violations. Applying the recommended fixes improved the maintainability and security of the Wildlife Sightings program. The final analysis reported a Pylint score of 10.00/10, no Bandit findings, and no Flake8 violations.